NKUST · DEVELOPER INTEGRATION

OIDC 單一登入

Authorization Code + PKCE S256

適合已具備 OIDC 模組或能安裝 OIDC 用戶端套件的接收系統。本版是後端保存密鑰的機密用戶端；純前端 SPA 需由後端處理登入。

1. **瀏覽器 → 接收系統 /login**
   套件產生並保存 state、nonce、PKCE verifier，綁定此次瀏覽器請求。
2. **瀏覽器 → 中央 /connect/authorize**
   帶 client_id、redirect_uri、scope、state、nonce、PKCE challenge。
3. **中央檢查登入狀態**
   有有效登入就沿用；否則在中央輸入帳密。
4. **中央 → 接收系統回呼**
   瀏覽器帶回 code 與 state；接收端先驗證關聯。
5. **接收系統後端 → 中央 /connect/token**
   使用授權碼、verifier 與用戶端驗證兌換。
6. **接收系統建立本地登入**
   套件驗證 ID Token；以 iss + sub 對應帳號，再檢查業務權限。

設定	值
Discovery	https://sso.example.edu/.well-known/openid-configuration
Authorization / Token	GET /connect/authorize；POST /connect/token
response_type / PKCE	code / S256
Scope	openid 必須；需要時加 profile、student_profile
回呼 / 用戶端驗證	精確 HTTPS 回呼；Client ID 與 Client Secret 留在後端

> 本文件為目前開發版介面規格；正式網址、系統代碼、密鑰 / 憑證、授權欄位與測試帳號請向 SSO 管理者取得。example.edu 為示意位址，不可直接呼叫。

OIDC 單一登入

Authorization Code + PKCE S256

瀏覽器請求及後端兌換欄位

階段	欄位與規則
授權請求	client_id、redirect_uri、response_type=code、scope=openid…、state、nonce、code_challenge、code_challenge_method=S256。由套件建立與編碼。
回呼	成功 code + state；錯誤可能為 error。先驗 state / 關聯，不因收到參數就視為成功。
Token POST	application/x-www-form-urlencoded：grant_type=authorization_code、code、redirect_uri、code_verifier；用戶端認證方式依可信 Discovery / 套件設定。
ID Token 驗證	由套件驗證簽章、iss、aud、exp、nonce 與協定關聯；解析 JWT 內容不等於驗證。
本地帳號鍵	使用可信 iss + sub；不要只按姓名或 email 自動合併帳號。

可取得的身分欄位

欄位	Scope	意義
preferred_username	profile	校園登入帳號；學生為學號、教職員為員編
name	profile	姓名
identity_type	student_profile	身分類型，例如 student / employee；依實際來源，不自行推測
class_code	student_profile	班級代碼
class_name	student_profile	班級名稱
student_status_code	student_profile	學籍狀態代碼
student_status_name	student_profile	學籍狀態名稱
education_level_code	student_profile	學制代碼
education_level_name	student_profile	學制名稱

所有可選欄位同時受該系統的欄位白名單限制；要求 scope 不代表一定取得欄位。固定識別碼 sub 與 iss / aud / exp 等協定欄位由 OIDC 回應提供。空白來源資料不代表未授權，也不可自行猜值。

> 授權碼本版有效 1 分鐘、ID Token 5 分鐘；實際以回應及驗證結果為準。未提供 UserInfo、Refresh Token、PAR 或通用業務 API 授權；不要要求 offline_access，也不要把 ID Token 當作業務 API 通行證。

OIDC 單一登入

Authorization Code + PKCE S256

設定範例：交給所使用的 OIDC 套件

```
Authority = "https://sso.example.edu/"
ClientId = "YOUR_CLIENT_ID"
ClientSecret = secretStore.Read("SSO_CLIENT_SECRET")
ResponseType = "code"
UsePkce = true
RedirectUri = "https://app.example.edu/signin-oidc"
Scopes = ["openid", "profile", "student_profile"]
GetClaimsFromUserInfoEndpoint = false
MapInboundClaims = false  // 若套件具備此選項，保留原 claim 名稱
```

以上是套件設定示意，不是可直接執行的程式。由框架處理 challenge、回呼、state / nonce、PKCE 與 Token 驗證；使用框架認證成功事件執行本地帳號查找。

```
onValidatedIdentity(identity):
    account = findLocalAccount(identity.issuer, identity.subject)
    if account is missing or account.disabled:
        reject("帳號尚未開通或已停用")
    checkLocalPermissions(account)
    createLocalSession(account, configuredLocalExpiry)
    redirectToAllowedLocalPage()
```

測試及登出

- 正常登入、中央已登入與登入逾時三種情境都要測試。
- 錯誤回呼、錯誤密鑰 / 簽章、票券重放、停用系統與停用帳號必須拒絕。
- 只有允許的欄位才可使用；欄位缺少或空白要能處理。
- 本地帳號未開通或沒有業務權限時顯示拒絕頁，不自動授予管理權。
- 登入後導向不含 code / ticket 的站內頁面；日誌不留原始密鑰、票券或 Token。

> 中央與接收系統各自建立 Cookie / Session。中央登入有效可省略再次輸入帳密；接收系統仍須完成驗證。中央登出不等於所有下游同時登出，本版未實作完整跨系統單一登出。

中央登出端點 /connect/logout：GET 顯示確認，實際登出由 POST 與防偽驗證執行。請先訂定接收系統自己的登出行為與登入期限。

規範參考：OpenID Connect Core、RFC 7636（PKCE）。本專案支援範圍以本文件及部署端 Discovery 為準。

實作核對：src/NkustSso.Server/Program.cs；Controllers/OidcAuthorizationController.cs；Services/OidcIdentityClaims.cs；Services/IdentityClaimReleasePolicy.cs